

Gastón Enrique Christianini Buela
Guilherme Teixeira Gomes
João Pedro Lopes de Sousa Gomes

Implementação de sistema de monitoramento de tráfego resistente à vigilância em massa

São Paulo, SP

2026

Gastón Enrique Christianini Buela
Guilherme Teixeira Gomes
João Pedro Lopes de Sousa Gomes

Implementação de sistema de monitoramento de tráfego resistente à vigilância em massa

Trabalho de conclusão de curso apresentado
ao Departamento de Engenharia de Computa-
ção e Sistemas Digitais da Escola Politécnica
da Universidade de São Paulo para obtenção
do Título de Engenheiro.

Universidade de São Paulo – USP

Escola Politécnica

Departamento de Engenharia de Computação e Sistemas Digitais (PCS)

Orientador: Prof. Dr. Thales Areco Bandiera Paiva

São Paulo, SP

2026

Resumo

Este projeto apresenta um sistema de proteção para bases de dados de monitoramento de tráfego veicular que utiliza mecanismos criptográficos para equilibrar a segurança pública e a privacidade individual. A solução proposta fundamenta-se na tese de *Crypto Crumple Zones* (WRIGHT; VARIA, 2018), que propõe o uso de criptografia para impor um custo para cada mensagem ou dado recuperado pelas autoridades. Entretanto, enquanto a tese original se concentra em aplicações genéricas, o presente trabalho aborda as especificidades do monitoramento de tráfego, que traz desafios próprios, como o volume massivo de dados sensíveis gerados por câmeras de monitoramento de placas que, se acessados sem restrições, permitem a vigilância indiscriminada da população. Diferente de modelos tradicionais de acesso total, esta abordagem garante que o custo para acessar dados de um veículo específico seja baixo, mas que o custo acumulado para acessar grandes volumes de dados torne a vigilância em massa economicamente inviável. Dessa forma, garante-se o princípio da proporcionalidade nas investigações policiais, permitindo o acesso legal mediante esforço institucional, enquanto se protege a massa de dados de cidadãos comuns contra acessos arbitrários (WRIGHT; VARIA, 2018)

Sumário

1	INTRODUÇÃO	4
1.1	Motivação	4
1.2	Objetivos	4
1.3	Justificativa	5
2	ASPECTOS CONCEITUAIS	6
2.1	Modelo de Sistema	6
2.2	Modelo de Adversário e Ameaças	7
3	MÉTODO DO TRABALHO	9
3.1	Arquitetura com BOLO e desbloqueio excepcional por quórum	9
3.2	Arquitetura de Vigilância Criptografada com Governança por Quórum e Desbloqueio de Exceção.	10
3.3	Arquitetura com Treshold Criptográfico	12
4	ESPECIFICAÇÃO DE REQUISITOS	14
4.1	Modalidades de Busca	15
4.2	Requisitos Funcionais	16
4.3	Requisitos Não-Funcionais	17
	REFERÊNCIAS	18

1 Introdução

O avanço de infraestruturas urbanas conectadas e a expansão de sistemas automáticos de leitura de placas ampliaram significativamente a capacidade de coleta e armazenamento de dados de deslocamento veicular. Embora esses sistemas contribuam para atividades legítimas de segurança pública e investigação criminal, também introduzem riscos relevantes à privacidade individual, sobretudo quando o acesso às bases ocorre de forma ampla, contínua e pouco proporcional. Nesse contexto, este trabalho investiga uma abordagem criptográfica para impor limites econômicos ao acesso massivo de dados, preservando a utilidade investigativa em casos específicos e reduzindo a viabilidade prática da vigilância indiscriminada.

1.1 Motivação

A digitalização do monitoramento de tráfego transformou bases de dados veiculares em ativos estratégicos para o Estado, mas também em pontos críticos de potencial abuso. Em especial, a coleta contínua por câmeras de leitura de placas gera grandes volumes de informações sensíveis sobre rotinas, deslocamentos e padrões de comportamento da população. Sem mecanismos técnicos de contenção, o acesso a esse tipo de base pode favorecer práticas de vigilância em massa, incompatíveis com princípios de necessidade, proporcionalidade e minimização de dados.

Como referência conceitual, a tese de *Crypto Crumple Zones* (WRIGHT; VARIA, 2018) propõe o uso de criptografia para impor um custo por dado recuperado, criando um freio econômico ao acesso irrestrito. Motivado por essa ideia, este projeto direciona a discussão para o domínio específico do monitoramento veicular, no qual o problema assume maior complexidade devido ao volume, à granularidade temporal dos registros e ao potencial de rastreamento populacional. Assim, a motivação central é desenvolver uma solução que preserve a capacidade investigativa em situações legítimas, sem permitir que a mesma infraestrutura seja utilizada para vigilância em massa da população

1.2 Objetivos

O principal objetivo deste projeto é desenvolver um sistema de proteção para bases de dados de monitoramento veicular que utilize a criptografia para condicionar o acesso à informação ao gasto de recursos computacionais, inibindo tecnologicamente a vigilância em massa. Para isso, o trabalho busca implementar chaves de criptografia independentes

para cada registro de placa capturado, garantindo que o custo de acesso seja individual e escale de forma linear.

O projeto visa calibrar a dificuldade criptográfica para que o custo de decodificação de um veículo seja economicamente aceitável para investigações legítimas, mas orçamentariamente proibitivo para o monitoramento em larga escala.

Por fim, será feita uma análise da viabilidade técnica e econômica do modelo proposto, enfatizando o *trade-off* entre segurança e usabilidade em um contexto real.

1.3 Justificativa

Este trabalho se justifica pela necessidade de conciliar dois interesses públicos legítimos e, muitas vezes, tensionados: a eficiência das investigações criminais e a proteção da privacidade dos cidadãos. Modelos tradicionais de acesso integral às bases de monitoramento tendem a tratar consultas pontuais e varreduras massivas com o mesmo custo operacional, o que pode estimular usos desproporcionais da informação. Ao introduzir um custo criptográfico por registro acessado, a proposta busca alterar esse incentivo: consultas direcionadas permanecem viáveis, enquanto extrações em larga escala tornam-se progressivamente mais caras.

Do ponto de vista técnico e social, a abordagem é relevante por incorporar o princípio da proporcionalidade ao próprio desenho do sistema, deslocando parte da governança do campo exclusivamente normativo para o campo tecnológico. Em vez de depender apenas de controles administrativos ou legais, o mecanismo criptográfico atua como barreira prática contra acessos arbitrários, reforçando garantias institucionais de proteção de dados. Além disso, ao adaptar os princípios de *Crypto Crumple Zones* ao cenário de tráfego veicular (WRIGHT; VARIA, 2018), o trabalho contribui para a literatura aplicada em segurança da informação e privacidade, oferecendo um modelo com potencial de adoção em contextos reais.

2 Aspectos Conceituais

Este capítulo apresenta os fundamentos conceituais que sustentam a proposta desta pesquisa, organizando os elementos teóricos e de modelagem necessários para a compreensão do sistema. Primeiramente, descreve-se o modelo de sistema adotado, com a definição das entidades, de seus papéis institucionais e dos mecanismos criptográficos que viabilizam o controle econômico do acesso aos dados de monitoramento veicular. Em seguida, formaliza-se o modelo de adversário e as principais ameaças consideradas, destacando as hipóteses de segurança, os vetores de abuso e as estratégias de mitigação aplicáveis ao contexto de monitoramento de tráfego urbano.

2.1 Modelo de Sistema

Para endereçar os desafios de preservação da privacidade e manutenção da segurança pública no monitoramento de tráfego na cidade de São Paulo, definimos um ecossistema composto por seis entidades principais. Esta arquitetura visa distribuir a confiança entre diferentes atores municipais e estaduais para mitigar o risco de pontos únicos de falha e garantir a proporcionalidade no acesso aos dados.

O Coletor ($\mathcal{C}$) compreende os agentes de borda, representados pela rede de câmeras de monitoramento com reconhecimento automático de placas (câmeras ALPR) geridas pela Companhia de Engenharia de Tráfego (CET) ou integradas ao programa City Câmeras. O $\mathcal{C}$ é responsável pela captura inicial da placa e geração dos metadados veiculares. Antes da transmissão, o $\mathcal{C}$ realiza o "amassamento" (*crumpling*) das chaves criptográficas através de funções de hash. O texto claro da placa é descartado imediatamente após a cifragem para impedir a replicação de informações pessoalmente identificáveis (PII) na origem, de modo que o sistema retenha apenas registros cuja recuperação exige esforço computacional.

O Servidor ($\mathcal{S}$) atua como o custodiante tecnológico da base de dados criptografada, função desempenhada por centros de processamento de dados como a Prodesp. O $\mathcal{S}$ armazena os registros "amassados" e gerencia as interfaces de consulta, operando estritamente no domínio cifrado. O servidor é considerado semi-honesto, executando as operações de busca sem possuir as chaves de decodificação ou a capacidade de acessar os dados de forma arbitrária sem o devido empenho de recursos.

O Usuário ($\mathcal{U}$) representa a autoridade investigativa, como as delegacias especializadas da Polícia Civil de São Paulo ou a Polícia Federal, que detém interesse legítimo em acessar registros de um veículo específico. Em investigações rotineiras, o $\mathcal{U}$ deve obrigatoriamente empenhar recursos computacionais reais, como ciclos de CPU e energia,

para resolver o puzzle de prova de trabalho (proof-of-work) associado a cada registro desejado. Este mecanismo impõe um custo linear que atua como barreira técnica contra o monitoramento indiscriminado da malha viária paulistana.

O controle institucional é exercido pelo Autorizador Legal e pelo Conselho de Governança. O Autorizador Legal, tipicamente representado pelo Poder Judiciário, analisa a validade jurídica das quebras de sigilo e emite tokens de autorização necessários para legitimar o início do gasto computacional. Paralelamente, o Conselho de Governança funciona como o Auditor de Parâmetros e Integridade. Este órgão define os níveis de entropia (l) dos puzzles para equilibrar a viabilidade das investigações e a segurança da população, além de realizar a auditoria retroativa dos registros para verificar se o volume de decodificações processadas pelo Usuário corresponde estritamente às autorizações emitidas.

Por fim, o Comitê de Emergência é a entidade responsável pelo Acesso Excepcional em cenários de extrema gravidade. Este comitê detém fragmentos de segredos que, quando combinados através de esquemas de custódia federada, permitem resolver puzzles de abrasão de alta complexidade. Este mecanismo desbloqueia uma infraestrutura de decodificação acelerada, garantindo que o acesso em situações críticas deixe um rastro orçamentário público e auditável, impedindo suspensões sigilosas das garantias de privacidade.

2.2 Modelo de Adversário e Ameaças

Adotamos um modelo de ameaça semi-honesto (honest-but-curious) ([MARTIN et al., 2025](#)), no qual assume-se que o Usuário ($\mathcal{U}$) e o Servidor ($\mathcal{S}$) executam o protocolo conforme especificado, mas tentam extrair o máximo de informação possível a partir dos dados cifrados aos quais possuem acesso legítimo. A validade desta premissa no sistema de monitoramento de São Paulo sustenta-se no fato de as entidades envolvidas serem órgãos públicos sujeitos a regimes rigorosos de fiscalização e auditoria. Nesses contextos, o custo político e judicial derivado de uma má conduta detectada atua como um incentivo direto ao comportamento conforme as regras, tornando tentativas de sabotagem ativa menos prováveis que a "curiosidade" passiva sobre os dados. Além disso, a separação de papéis aliada à auditoria retroativa do Conselho de Governança assegura que qualquer tentativa de burlar as barreiras econômicas exigiria um investimento orçamentário visível e tecnologicamente proibitivo.

A segurança do protocolo fundamenta-se na Independência de Chaves, garantindo que a solução de um puzzle para um registro específico (um avistamento de placa em um determinado cruzamento) não reduza o custo de recuperação de registros subsequentes ou de outros veículos, mantendo a vigilância orçamentariamente rastreável e limitada. Assim, mesmo um adversário semi-honesto que analise exaustivamente os valores cifrados não consegue distinguir as mensagens de valores aleatórios sem o empenho do custo

computacional linear previsto.

O modelo identifica e mitiga as seguintes ameaças críticas no contexto de monitoramento de tráfego na cidade de São Paulo ([OWASP FOUNDATION](#), s.d.):

- **Vazamento de Informação em massa:** risco de reconstrução de trajetórias e inferência de destinos de cidadãos não-alvos. Devido à alta densidade da rede viária de São Paulo, a captura frequente permite localizar veículos com precisão preocupante (menos de 1 km de incerteza) ([BOYER et al., 2018](#)). O sistema mitiga este risco ao converter a facilidade tecnológica de acesso em um impedimento econômico intransponível para orçamentos públicos finitos, através do custo computacional por registro.
- **Corrupção Institucional e Abuso de Poder:** risco de um agente isolado desviar o sistema para finalidades de vigilância política ou perseguição pessoal. A atuação do Conselho de Governança como auditor externo e a custódia de chaves para emergências garantem que nenhum indivíduo detenha o poder total de suspender as garantias de privacidade de forma sigilosa.
- **Adulteração e Falsificação:** tentativas de modificar registros no servidor para ocultar trajetos de suspeitos ou forjar evidências contra inocentes. Protocolos de autenticidade asseguram que apenas registros originados no Coletor ($\mathcal{C}$) e autorizados judicialmente sejam processados, protegendo a integridade da prova e evitando a inserção de dados falsos por adversários.
- **Ataque de Reutilização de Esforço:** ameaça de um adversário reaproveitar a solução de um registro para descriptografar outros de forma barata (ex.: ataques de dicionário ou tabelas de pré-computação). O uso de identificadores contextuais únicos, como endereços de câmeras e carimbos de tempo precisos no processo de *crumpling*, garante que cada processo de decodificação seja independente, único e não-reutilizável.

O sistema é considerado seguro se o esforço necessário para realizar uma vigilância indiscriminada for tecnologicamente garantido como proibitivo, forçando a autoridade a fundamentar cada busca na necessidade investigativa e na disponibilidade orçamentária fiscalizada pelo Conselho de Governança.

3 Método do trabalho

O presente capítulo discute três ideias de arquitetura para o sistema proposto, com o objetivo de identificar alternativas viáveis para equilibrar segurança, privacidade e custo operacional no contexto de monitoramento veicular. Em vez de apresentar uma implementação final, o foco está na formulação e análise comparativa das abordagens candidatas, destacando seus pressupostos, vantagens, limitações e requisitos técnicos.

3.1 Arquitetura com BOLO e desbloqueio excepcional por quórum

Esta arquitetura parte de duas premissas de projeto: (i) o sistema não pode impedir o uso operacional das câmeras para consultas do tipo *Be On the Lookout* (BOLO), como comparação com bases de veículos roubados, mandados de busca e casos de *Amber Alert*; e (ii) o mesmo sistema deve dificultar tecnicamente a vigilância em massa da população. Para atender a essas premissas, o modelo separa o fluxo de resposta imediata do fluxo de acesso investigativo retrospectivo.

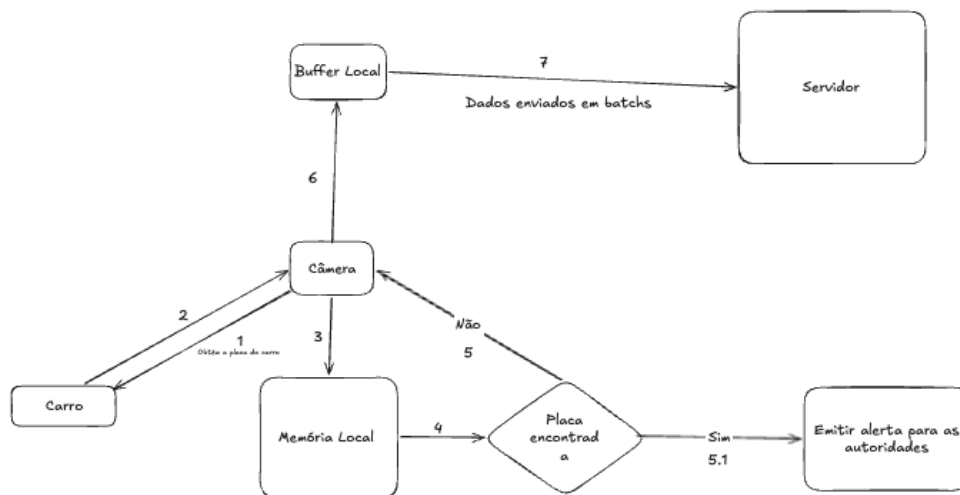


Figura 1 – Desenho da arquitetura proposta com fluxo BOLO e desbloqueio excepcional por quórum.

No fluxo BOLO, a verificação ocorre de forma direcionada e orientada por lista de interesse previamente definida, permitindo alertas em tempo quase real quando houver correspondência com alvos específicos. No fluxo de armazenamento, cada câmera possui um identificador único no banco de dados e registra, para cada captura, a placa em formato criptografado, o horário do evento e metadados veiculares relevantes. Essa estrutura permite

rastreabilidade por origem e por janela temporal, sem expor diretamente o conteúdo em texto claro.

Como mecanismo de contenção institucional para acessos amplos, a arquitetura prevê uma chave mestre fracionada entre oito representantes (deputados estaduais), em esquema de compartilhamento de segredo, onde metade deve se juntar para obter a chave. Assim, somente a reunião de pelo menos quatro partes autorizadas permite reconstruir a chave de exceção para abrir informações de múltiplas câmeras em um período de interesse. Portanto, acessos extraordinários deixam de depender de decisão unilateral e passam a exigir coordenação política explícita, aumentando auditabilidade e custo institucional de consultas massivas.

Em síntese, a proposta busca preservar a efetividade do BOLO para casos urgentes e específicos, enquanto impõe barreiras técnicas e de governança contra uso indiscriminado da base histórica.

3.2 Arquitetura de Vigilância Criptografada com Governança por Quórum e Desbloqueio de Exceção.

A arquitetura proposta organiza-se como um ecossistema de custódia de dados fundamentado no princípio da segurança em múltiplas camadas, estruturando-se em quatro eixos fundamentais: captura e proteção na borda, custódia cega, governança de acesso e mecanismos de exceção. O design tem como objetivo primordial garantir a privacidade dos cidadãos através de um custo computacional linear por registro decodificado e de uma rastreabilidade institucional perene, alinhando-se tecnicamente à tese das Crypto Crumple Zones e ao princípio jurídico da proporcionalidade nas quebras de sigilo.

O ciclo de vida do dado inicia-se na Camada de Borda, especificamente no coletor ALPR, onde a privacidade é assegurada pelo método de Crumpling. Neste estágio, os dados brutos são transformados em estruturas criptográficas complexas antes de qualquer transmissão para a rede. Para cada captura — que compreende a placa, localização, timestamp e identificador da câmara — o coletor gera uma chave mestra aleatória k_0 de 256 bits e deriva uma chave de cifragem secundária k_{ccz} via SHA-256. O payload, contendo informações sensíveis como latitude e longitude, é cifrado utilizando o algoritmo AES-256-GCM. Este protocolo é reforçado pelo uso de Associated Data (AD), que vincula o cifrado ao contexto específico da captura, garantindo que qualquer alteração no ciphertext ou no identificador da câmara invalide a decifragem. Complementarmente, o sistema gera um "puzzle" criptográfico ao revelar apenas uma fração de k_0 , mantendo uma entropia oculta de l bits. Este puzzle atua como uma barreira de latência deliberada, exigindo prova de trabalho para a recuperação da chave e impedindo tecnicamente a decodificação em massa não autorizada. Após o envio do pacote cifrado, o texto claro da placa e a chave k_0

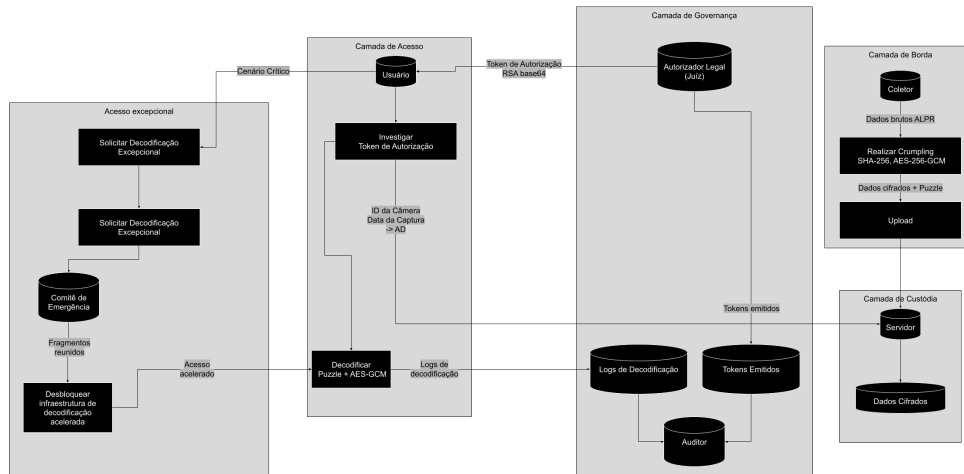


Figura 2 – Fluxograma da Arquitetura de Vigilância Criptografada, destacando a separação entre a captura de dados na borda, a custódia segura e o modelo de governança baseado em autorização judicial e quórum político para acessos de exceção.

completa são permanentemente descartados na borda.

Na sequência, os pacotes são transmitidos para a Camada de Custódia, onde o servidor central atua como um repositório cego. Nesta fase, os dados permanecem em repouso estritamente cifrados, e o servidor, embora responsável pelo armazenamento, não possui as chaves necessárias para a leitura do conteúdo. A indexação é realizada exclusivamente por metadados não sensíveis, permitindo a localização temporal e geográfica de eventos sem expor a identidade dos alvos, sendo que a liberação de qualquer conteúdo condicional à apresentação de um token de autorização válido.

A Camada de Governança e a Camada de Acesso medeiam o fluxo de informação. A decodificação de um registro exige a intervenção de um Autorizador Legal (Magistrado), que emite um token de autorização baseado em criptografia assimétrica RSA. O servidor utiliza a chave pública para verificar a assinatura digital em base64 e o vínculo do token com os dados solicitados. Este mecanismo é estritamente granular, restringindo o acesso apenas ao escopo autorizado. Para garantir a conformidade e coibir abusos, um Auditor realiza a reconciliação contínua entre os tokens emitidos e os logs de decodificação, estabelecendo uma trilha de auditoria que permite verificar se o volume de dados processados corresponde estritamente às ordens judiciais expedidas.

Por fim, para mitigar o risco de vigilância em massa ou abusos unilaterais, a arquitetura implementa um Mecanismo de Exceção gerido por um Comitê de Emergência. Em cenários críticos, o acesso à infraestrutura de decodificação acelerada — necessária para resolver grandes volumes de puzzles em tempo útil — depende da reconstrução de uma chave mestra fragmentada via esquemas de segredo compartilhado. O desbloqueio do sistema só ocorre quando um quórum predefinido de representantes reúne os seus fragmentos. Esta abordagem transmuta uma limitação técnica numa salvaguarda política de alto nível, garantindo que qualquer tentativa de vigilância em larga escala exija coordenação institucional e deixe rastros administrativos e políticos indelévels.

3.3 Arquitetura com Treshold Criptográfico

A robustez deste modelo de governança reside na imposição de barreiras multicamadas para o acesso aos dados, diferenciando o uso rotineiro da análise de exceção. Para o Acesso Comum, a arquitetura estabelece um limiar técnico-administrativo: a liberação de dados depende da apresentação de um Token de Autorização emitido pelo Judiciário, somado obrigatoriamente a uma Prova de Trabalho (*Proof-of-Work* - PoW) realizada pela infraestrutura da Polícia. Esse requisito de gasto computacional atua como um desincentivo econômico e técnico contra varreduras massivas e consultas automatizadas sem alvo definido.

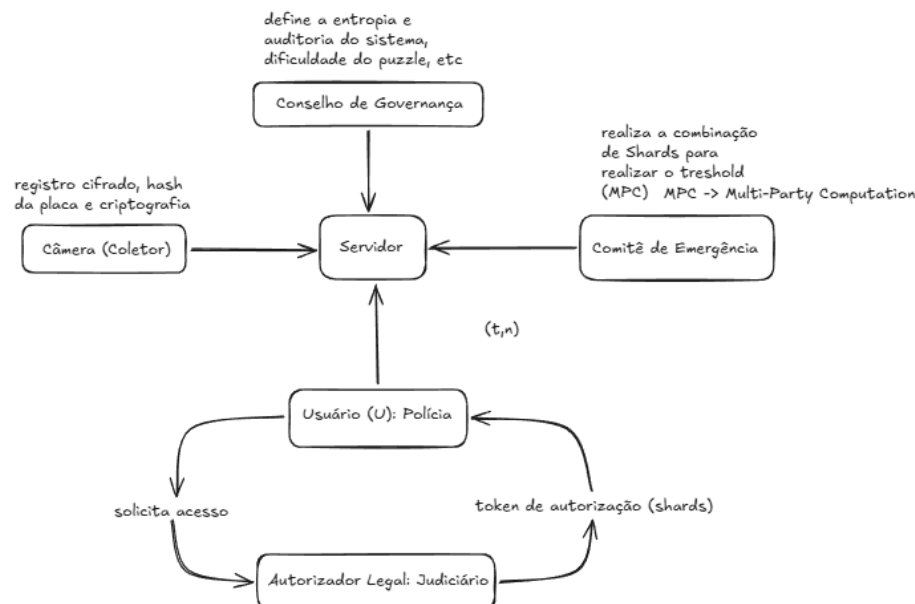


Figura 3 – Desenho da arquitetura proposta com treshold criptográfico.

Para cenários de Acesso Excepcional, onde a urgência ou a sensibilidade superam os trâmites do fluxo comum, a arquitetura introduz um Comitê de Emergência. Neste

nível, a chave de acesso é fragmentada em *shards* distribuídos entre os membros do comitê via *Multi-Party Computation* (MPC). A reconstrução da autorização exige que um quórum mínimo (limiar) de membros forneça suas partes, garantindo que nenhum agente isolado, nem mesmo o administrador do sistema, possua controle total sobre a base histórica de placas (ALPR).

Sob a supervisão de um Conselho de Governança, os parâmetros de esforço da PoW e os valores de limiar do comitê são calibrados e auditados periodicamente. Dessa forma, o projeto não apenas protege os dados através de criptografia, mas submete o acesso a um rastro de auditoria duplo: a necessidade de autorização externa e o custo computacional explícito, elevando o custo institucional de qualquer tentativa de vigilância indiscriminada.

Entretanto, a análise dessa arquitetura revelou uma vulnerabilidade persistente no estágio de execução do acesso excepcional: o risco de exposição da chave no momento da reconstrução. Ao exigir que os membros do comitê forneçam seus *shards* para a montagem do segredo dentro do ambiente computacional do solicitante, a chave mestra torna-se temporariamente visível e, portanto, tecnicamente comprometida para usos futuros. Essa fragilidade compromete a segurança do sistema, uma vez que a posse da chave reconstruída permitiria à entidade policial realizar consultas retroativas ou futuras sem a necessidade de uma nova convocação do quórum. Consequentemente, o modelo atual impõe um alto custo operacional de manutenção, exigindo que todo o conjunto de fragmentos seja resetado e redistribuído após cada ativação do fluxo de emergência para restauro de integridade.

4 Especificação de Requisitos

A análise comparativa das arquiteturas apresentadas no Capítulo 3 evidenciou que nenhuma das propostas individualmente atende de forma plena ao conjunto de objetivos do sistema. A arquitetura com BOLO (Seção 3.1) preserva a operacionalidade em tempo real, mas não formaliza mecanismos criptográficos robustos para o acesso investigativo retrospectivo. A Arquitetura de Vigilância Criptografada com Governança por Quórum (Seção 3.2) introduz camadas bem definidas de custódia e governança, porém não integra o fluxo BOLO ao modelo criptográfico. Por fim, a Arquitetura com Threshold Criptográfico (Seção 3.3), embora a mais completa do ponto de vista da governança distribuída, apresenta uma vulnerabilidade estrutural no momento de reconstrução da chave mestra: ao exigir que os fragmentos sejam reunidos no ambiente computacional do solicitante, a chave torna-se temporariamente exposta, comprometendo a integridade do sistema e exigindo um reset e redistribuição dos fragmentos após cada ativação do fluxo de emergência.

A Arquitetura 3.0, cujo diagrama está reproduzido na Figura 4, representa a síntese dessas três propostas e constitui a arquitetura selecionada para implementação. Ela incorpora o fluxo BOLO integrado ao ciclo de vida do dado criptografado, mantém as camadas de borda, custódia, governança e acesso da proposta anterior, e resolve a vulnerabilidade de exposição da chave ao adotar chaves mensais independentes — geradas como pares assimétricos (PK, SK) — cujos fragmentos são distribuídos ao Comitê de Emergência via Shamir’s Secret Sharing. Com isso, a reconstrução da chave para acesso excepcional fica circunscrita ao mês de interesse, impedindo que uma ativação do fluxo de emergência comprometa registros de outros períodos. Adicionalmente, a arquitetura formaliza três modalidades distintas de busca (Aberta, Fechada e Total), cada uma com escopo, custo computacional e requisitos de autorização próprios.

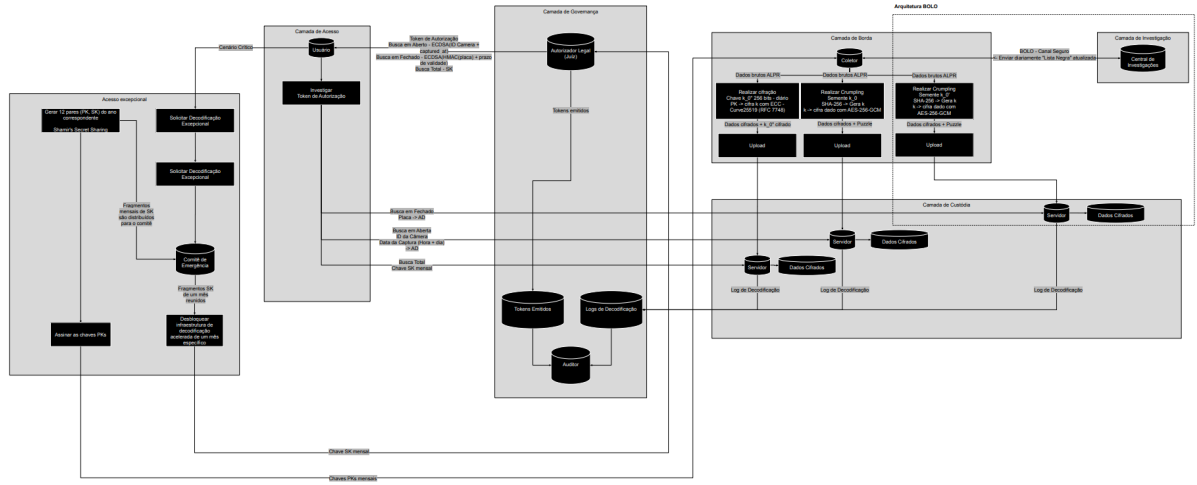


Figura 4 – Fluxograma da Arquitetura do Sistema

4.1 Modalidades de Busca

A Busca em Aberto é orientada por metadados não identificadores e destina-se à localização de eventos por câmera e por janela temporal. Nessa modalidade, o token de autorização é assinado com ECDSA sobre a combinação entre o identificador da câmera e o instante de captura ($ECDSA(ID_{camera} + captured_at)$). Como não há exposição direta da identidade do veículo, essa forma de consulta é adequada para auditorias de fluxo e verificações operacionais.

A Busca em Fechado visa um veículo específico e exige que o token de autorização vincule o HMAC da placa a um prazo de validade explícito ($ECDSA(HMAC_{placa} + prazo_de_validade)$). O prazo limita temporalmente o escopo da autorização, impedindo que uma ordem judicial seja reutilizada indefinidamente.

A Busca Total destina-se exclusivamente a cenários de acesso excepcional mediados pelo Comitê de Emergência. Nela, a chave secreta mensal (SK) é reconstruída a partir do quórum de fragmentos via Shamir's Secret Sharing e empregada para decifrar o conjunto de registros do período. Cada ativação deste fluxo gera um log de decodificação auditável e é restrita ao mês cujos fragmentos foram reunidos, sem comprometer chaves de outros períodos. Esta separação resolve diretamente a vulnerabilidade identificada na Seção 3.3: ao segmentar as chaves em granularidade mensal, uma ativação do fluxo de emergência não concede acesso retroativo ou prospectivo irrestrito — o impacto de cada ativação fica circunscrito ao mês específico, e o conjunto de fragmentos não necessita de reset global após cada uso.

4.2 Requisitos Funcionais

RF01 — Crumpling na borda: O coletor ALPR deve, para cada captura, gerar uma semente aleatória k_0 de 256 bits, derivar a chave de cifragem k via SHA-256, cifrar o payload com AES-256-GCM e descartar imediatamente o texto claro da placa e a semente k_0 após o upload.

RF02 — Puzzle criptográfico: O sistema deve gerar, junto a cada registro cifrado, um puzzle de prova de trabalho com entropia configurável pelo Conselho de Governança, de modo que a resolução do puzzle seja condição necessária para a decodificação de qualquer registro.

RF03 — Fluxo BOLO: O sistema deve suportar a consulta em tempo quase real de placas capturadas contra uma lista negra atualizada diariamente pela Central de Investigações via canal seguro, sem que essa verificação exija a decodificação do registro armazenado no servidor.

RF04 — Gestão de chaves mensais: O sistema deve gerar anualmente 12 pares de chaves assimétricas mensais (PK, SK) baseadas em criptografia de curva elíptica Curve25519 (RFC 7748), assinar as chaves públicas e distribuir os fragmentos das chaves secretas ao Comitê de Emergência via Shamir's Secret Sharing antes do início de cada mês.

RF05 — Cifragem com chave pública mensal: Na modalidade de Busca Total, o coletor deve cifrar a chave de sessão diária k_0'' com a chave pública mensal (PK) via ECC-Curve25519, armazenando o dado cifrado e a chave de sessão cifrada no servidor.

RF06 — Emissão e verificação de tokens de autorização: O sistema deve suportar a emissão de tokens de autorização assinados digitalmente pelo Autorizador Legal (Judiciário) e verificar sua assinatura e escopo antes de liberar qualquer operação de decodificação.

RF07 — Modalidades de busca diferenciadas: O sistema deve implementar as três modalidades de busca descritas na Seção 4.1, garantindo que cada modalidade exija o tipo de token correspondente e imponha o custo computacional adequado ao seu escopo.

RF08 — Log de decodificação: Toda operação de decodificação deve gerar um registro imutável de auditoria contendo ao menos: identificador do token utilizado, timestamp da operação, modalidade de busca e identificador do operador.

RF09 — Reconciliação de auditoria: O Auditor deve ter acesso a uma interface de reconciliação que permita cruzar os tokens emitidos pelo Autorizador Legal com os logs de decodificação gerados pelo servidor, sinalizando automaticamente qualquer discrepância entre o volume autorizado e o volume efetivamente decodificado.

RF10 — Acesso excepcional por quórum: O sistema deve implementar o fluxo de Busca Total de modo que a reconstrução da chave SK mensal exija um quórum mínimo

configurável de membros do Comitê de Emergência, e que a decodificação seja restrita ao mês cujos fragmentos foram reunidos.

4.3 Requisitos Não-Funcionais

RNF01 — Independência de chaves: A resolução de um puzzle ou a decodificação de um registro não deve reduzir o custo computacional para decodificação de nenhum outro registro, garantindo que o custo de vigilância em massa escale linearmente com o volume de dados acessados.

RNF02 — Confidencialidade na borda: O texto claro da placa não deve persistir em nenhum componente de borda após a cifragem e o upload do registro, eliminando a possibilidade de extração de PII a partir dos coletores.

RNF03 — Rastreabilidade perene: Toda operação de acesso, desde a emissão do token até a conclusão da decodificação, deve ser registrada de forma auditável e imutável, de modo que o volume de decodificações realizadas por um usuário seja verificável retroativamente pelo Conselho de Governança.

RNF04 — Isolamento temporal de chaves de emergência: A ativação do fluxo de Busca Total para um determinado mês não deve comprometer a confidencialidade dos registros de outros meses. Este requisito é garantido pela segmentação das chaves SK em granularidade mensal, resolvendo a vulnerabilidade identificada na Seção 3.3.

RNF05 — Proporcionalidade de custo: O parâmetro de entropia dos puzzles deve ser calibrado pelo Conselho de Governança de forma que o custo de decodificação de um único veículo seja operacionalmente viável para investigações legítimas, enquanto o custo acumulado de varreduras massivas seja orçamentariamente proibitivo para qualquer entidade com orçamento público finito.

RNF06 — Integridade dos registros: O uso de Associated Data (AD) no esquema AES-256-GCM deve garantir que qualquer adulteração no ciphertext ou nos metadados de câmera invalide a decifragem, protegendo a cadeia de custódia das evidências.

RNF07 — Disponibilidade do fluxo BOLO: O subsistema de consulta BOLO deve operar de forma independente do servidor de dados históricos, de modo que indisponibilidades na camada de custódia não interrompam alertas operacionais em tempo real.

RNF08 — Auditabilidade do Comitê de Emergência: Toda ativação do fluxo de Busca Total deve gerar rastros administrativos públicos e auditáveis, tornando qualquer tentativa de vigilância em larga escala institucionalmente visível e politicamente rastreável.

Referências

BOYER, K. et al. A characterization of the mass surveillance potential of road traffic monitors. In: GANAPATHY, V. et al. (Ed.). *Information Systems Security: 14th International Conference, ICISS 2018, Bangalore, India, December 17–19, 2018, Proceedings*. Cham: Springer, 2018, (Lecture Notes in Computer Science). p. 3–23. Citado na página 8.

MARTIN, S. et al. Hydia: Fhe-based facial matching with hybrid approximations and diagonalization. *Proceedings on Privacy Enhancing Technologies (PoPETs)*, v. 2025, n. 4, p. 585–604, 2025. Seções 4.1 e 4.2. Citado na página 7.

OWASP FOUNDATION. *Threat Modeling Process*. s.d. OWASP. Disponível em: https://owasp.org/www-community/Threat_Modeling_Process. Acesso em: 21 fev. 2026. Citado na página 8.

WRIGHT, C.; VARIA, M. Crypto crumple zones: Enabling limited access without mass surveillance. In: *2018 IEEE European Symposium on Security and Privacy (EuroSP)*. [S.l.: s.n.], 2018. p. 288–306. Citado 3 vezes nas páginas 2, 4 e 5.